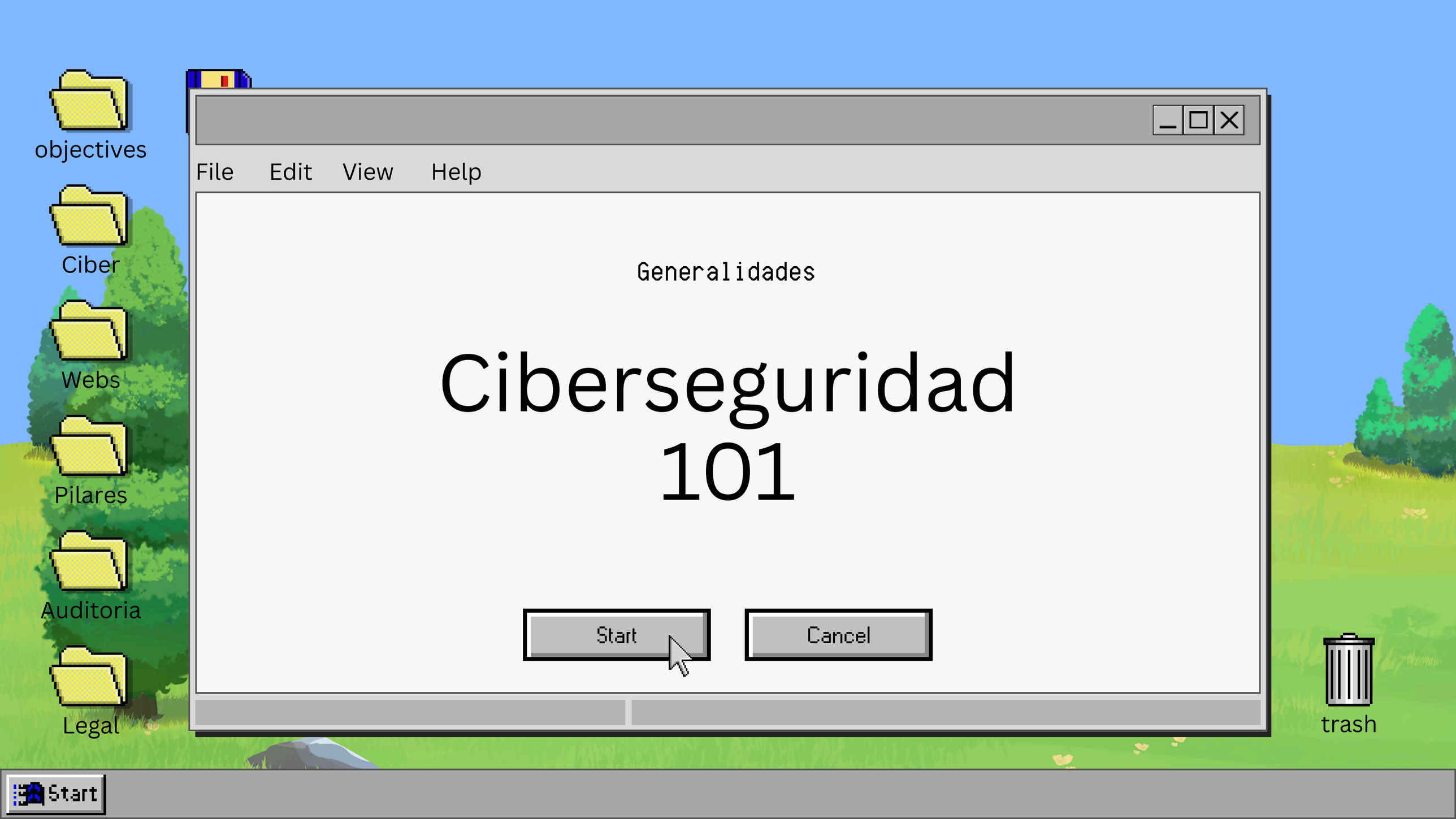

objectives
Ciber
Webs
Pilares
Auditoria
Legal
File
Edit
View
Help
Generalidades
Ciberseguridad
101
Start
Cancel
trash
Start

01

CONCEPTOS GENERALES

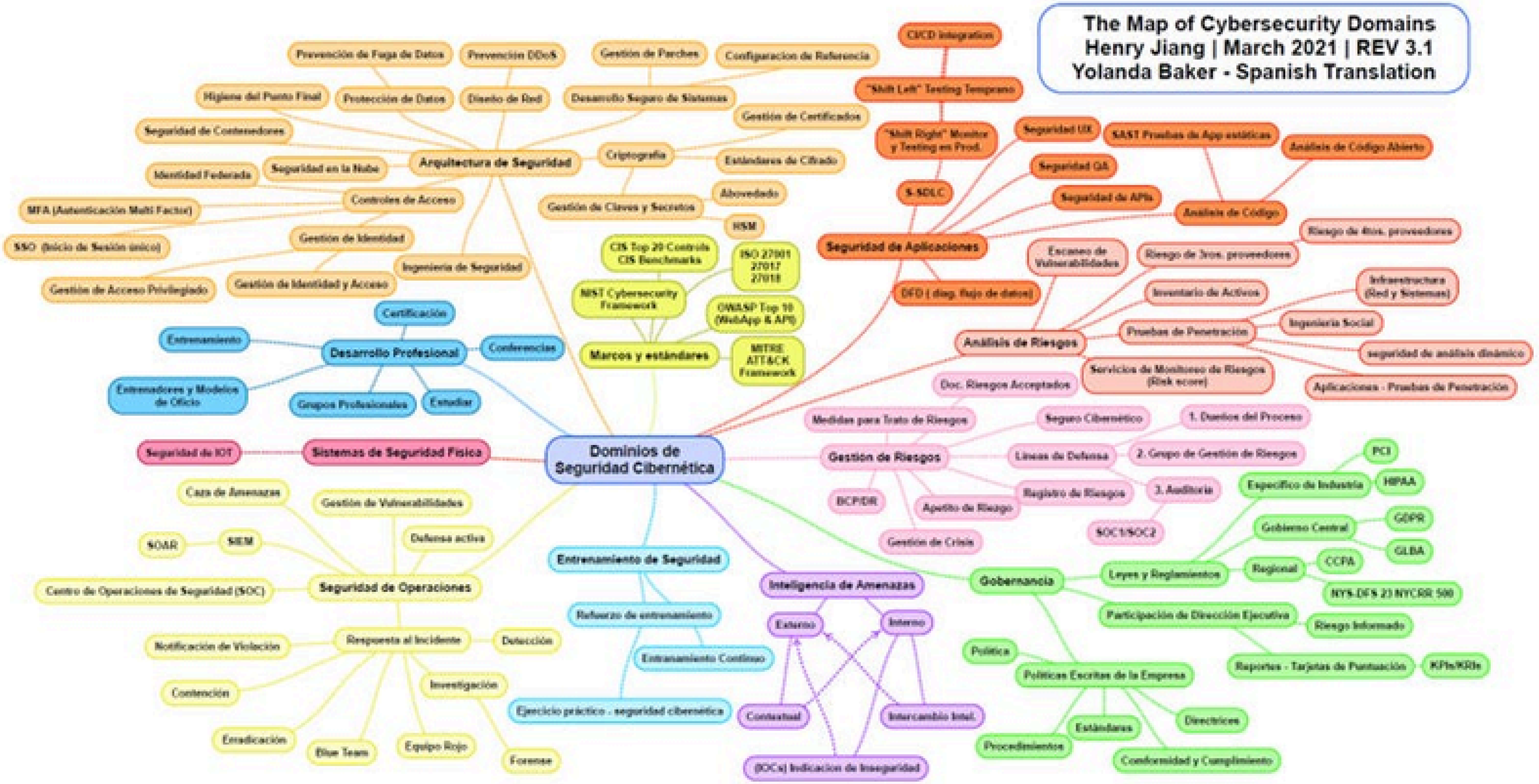
CIBERSEGURIDAD

Conjunto de prácticas, tecnologías, procesos y controles.

Se aplican para proteger sistemas, redes, aplicaciones y datos contra accesos no autorizados, daños, robo o interrupciones.

Su propósito es que la información y los servicios digitales sigan siendo confiables, correctos y disponibles para quienes tienen derecho a usarlos.




The Map of Cybersecurity Domains
Henry Jiang | March 2021 | REV 3.1
Yolanda Baker - Spanish Translation
Dominios de Seguridad Cibernética
Arquitectura de Seguridad
Prevención de Fuga de Datos
Prevención DDoS
Higiene del Punto Final
Protección de Datos
Diseño de Red
Seguridad de Contenedores
Seguridad en la Nube
Identidad Federada
Controles de Acceso
MFA (Autenticación Multi Factor)
SSO (Inicio de Sesión único)
Gestión de Identidad
Gestión de Acceso Privilegiado
Gestión de Identidad y Acceso
Ingeniería de Seguridad
Gestión de Parches
Configuracion de Referencia
Desarrollo Seguro de Sistemas
Criptografía
Gestión de Certificados
Estándares de Cifrado
Gestión de Claves y Secretos
Abovedado
HSM
Seguridad de Aplicaciones
CI/CD integration
"Shift Left" Testing Temprano
"Shift Right" Monitor y Testing en Prod.
S-SDLC
Seguridad UX
SAST Pruebas de App estáticas
Análisis de Código Abierto
Seguridad QA
Seguridad de APIs
Análisis de Código
Escaneo de Vulnerabilidades
DFD (diag. flujo de datos)
Riesgo de 4tos. proveedores
Riesgo de 3ros. proveedores
Análisis de Riesgos
Inventario de Activos
Infraestructura (Red y Sistemas)
Pruebas de Penetración
Ingeniería Social
seguridad de análisis dinámico
Servicios de Monitoreo de Riesgos (Risk score)
Aplicaciones - Pruebas de Penetración
Doc. Riesgos Aceptados
Gestión de Riesgos
Medidas para Trato de Riesgos
Seguro Cibernético
1. Dueños del Proceso
Líneas de Defensa
2. Grupo de Gestión de Riesgos
3. Auditoría
Registro de Riesgos
Apetito de Riesgo
BCP/DR
Gestión de Crisis
SOC1/SOC2
Gobernancia
Leyes y Reglamentos
Específico de Industria
PCI
HIPAA
Gobierno Central
GDPR
GLBA
Regional
CCPA
NYS-DFS 23 NYCRR 500
Participación de Dirección Ejecutiva
Riesgo Informado
Reportes - Tarjetas de Puntuación
KPIs/KRIs
Política
Políticas Escritas de la Empresa
Estándares
Directrices
Procedimientos
Conformidad y Cumplimiento
Marcos y estándares
CIS Top 20 Controls
CIS Benchmarks
ISO 27001
27017
27018
NIST Cybersecurity Framework
OWASP Top 10 (WebApp & API)
MITRE ATT&CK Framework
Desarrollo Profesional
Certificación
Entrenamiento
Conferencias
Entrenadores y Modelos de Oficio
Grupos Profesionales
Estudiar
Sistemas de Seguridad Física
Seguridad de IOT
Seguridad de Operaciones
Caza de Amenazas
Gestión de Vulnerabilidades
Defensa activa
SOAR
SIEM
Centro de Operaciones de Seguridad (SOC)
Respuesta al Incidente
Detección
Notificación de Violación
Contención
Investigación
Erradicación
Blue Team
Equipo Rojo
Forense
Entrenamiento de Seguridad
Refuerzo de entrenamiento
Entrenamiento Continuo
Ejercicio práctico . seguridad cibernética
Inteligencia de Amenazas
Externo
Interno
Contextual
Intercambio Intel.
(IOCs) Indicación de Inseguridad

Garantizar que sólo accede los autorizados

- Fuga de información
- Privacidad





Garantizar que los datos no han sido modificados.

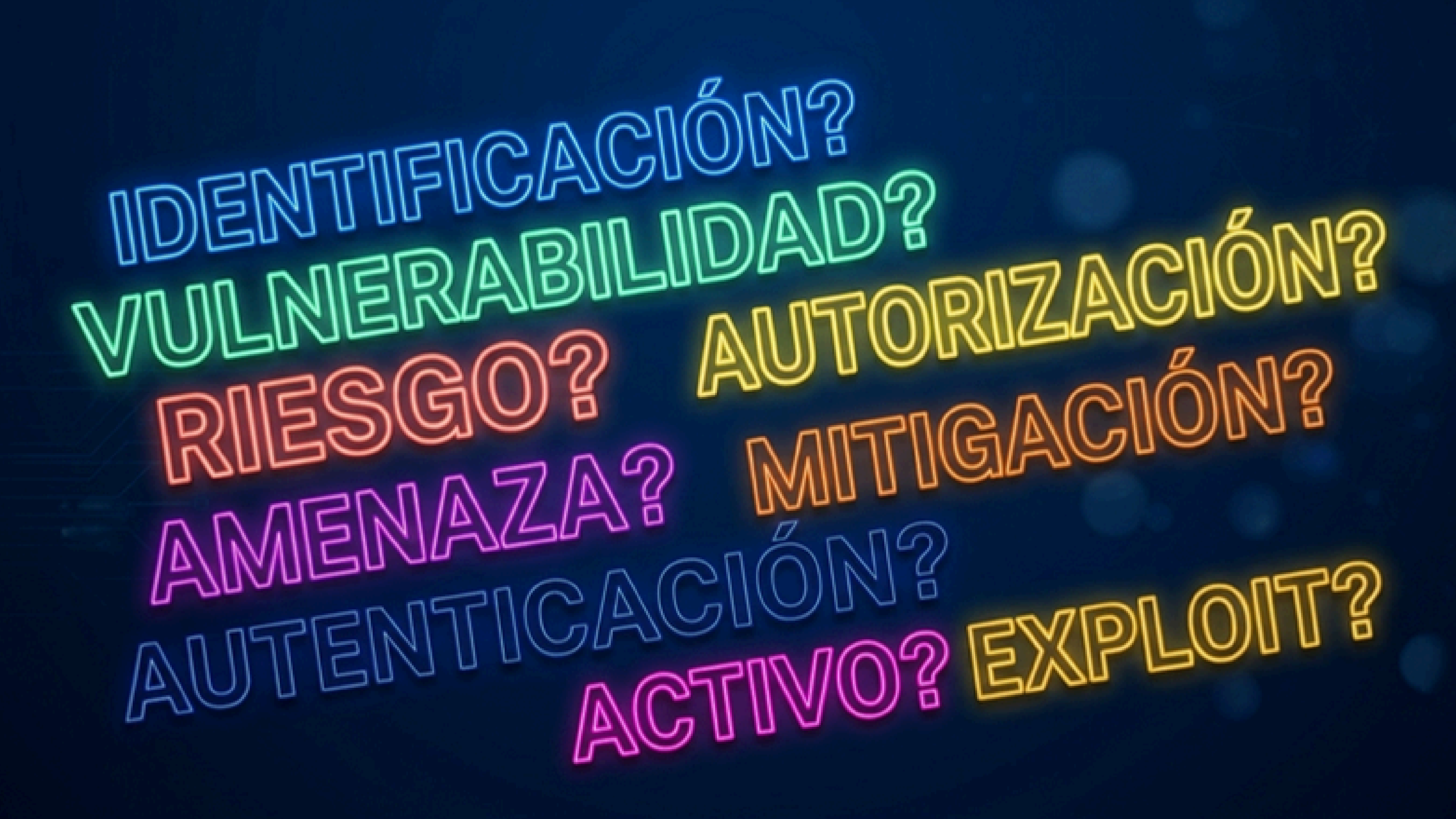
- Manipulación de la información
- Suplantación de identidad



Garantizar que los datos van a estar disponibles.

- Denegación de servicio
- Parada del servicio




IDENTIFICACIÓN?
VULNERABILIDAD?
RIESGO?
AUTORIZACIÓN?
AMENAZA?
MITIGACIÓN?
AUTENTICACIÓN?
ACTIVO?
EXPLOIT?

1



1. Activo

Información y sistemas valiosos para proteger

2



2. Vulnerabilidad

Debilidad o fallo de seguridad en el sistema

3



3. Amenaza

Cualquier agente externo con potencial de daño

4



4. Riesgo

Posibilidad de que ocurra una amenaza y su impacto

5



5. Exploit

Código o método que aprovecha una vulnerabilidad

6



6. Identificación

Reclamar la identidad de un usuario o sistema

7



7. Autenticación

Verificar la identidad declarada por el usuario

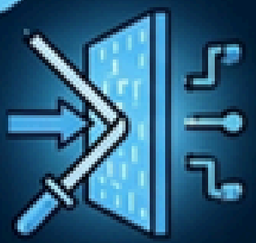
8



8. Autorización

Otorgar permisos específicos a un usuario verificado

9



9. Mitigación

Reducir la probabilidad o el impacto de un ataque

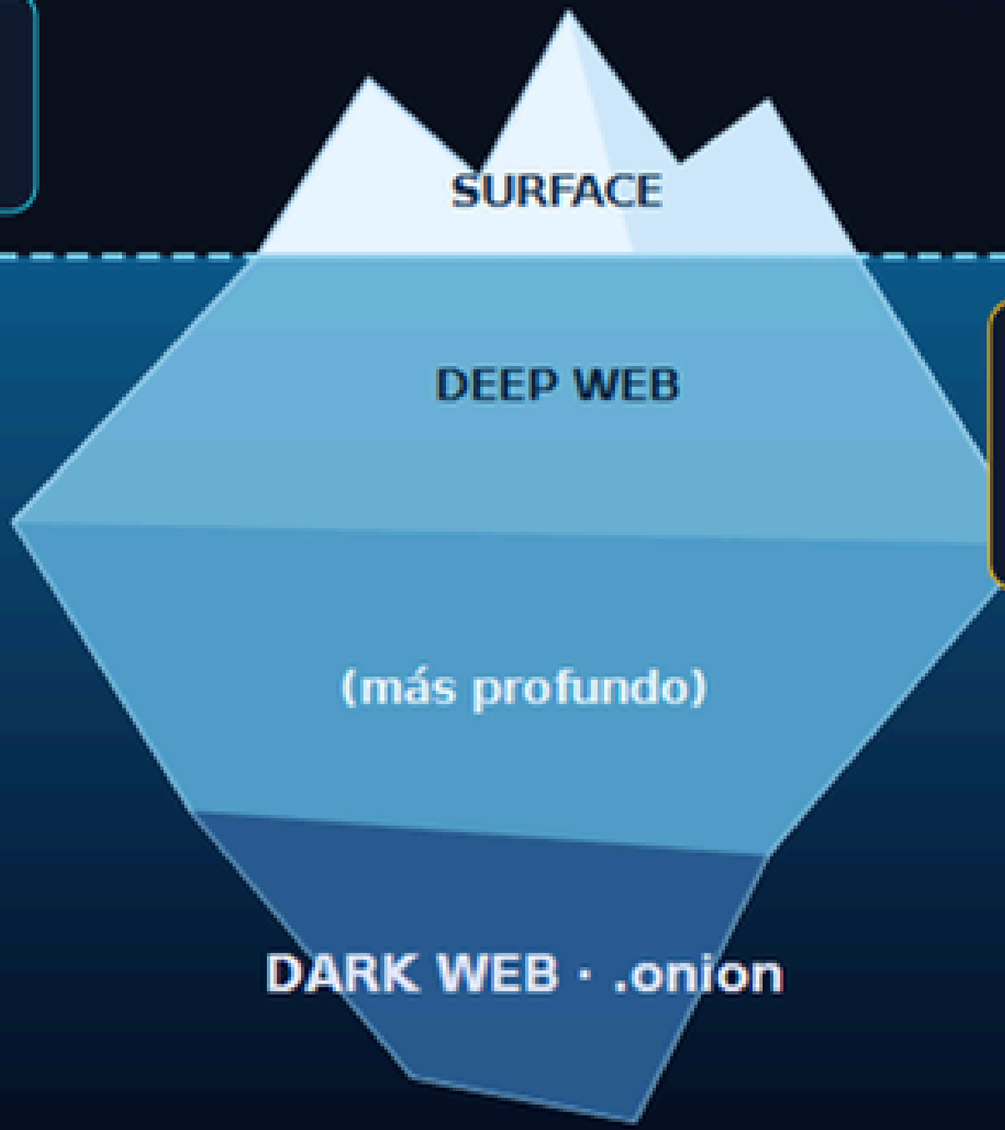
02



CAPAS DE LA WEB, CRAWLERS Y RED TOR

CAPAS DE LA WEB

🌐 Surface web · ~4-5% (est.)
Indexada por Google/Bing. Acceso libre.
Noticias, blogs, Wikipedia, tiendas.



── nivel del "buscador" ──

🕷 Línea de indexación
Todo lo que un crawler puede alcanzar por hipervínculos.

🔐 Deep web · la gran mayoría
NO indexada: requiere login/permiso.
Banca en línea, correo, intranets, expedientes médicos, bases de datos, paywalls, apps SaaS.

🕳 Dark web · porción mínima
Requiere software especial (Tor).
Dominios .onion, servicios ocultos.
Mixto: medios con espejo anti-censura, denunciantes… y mercados ilegales, filtraciones de datos.

⚠ Tor ≠ Dark web

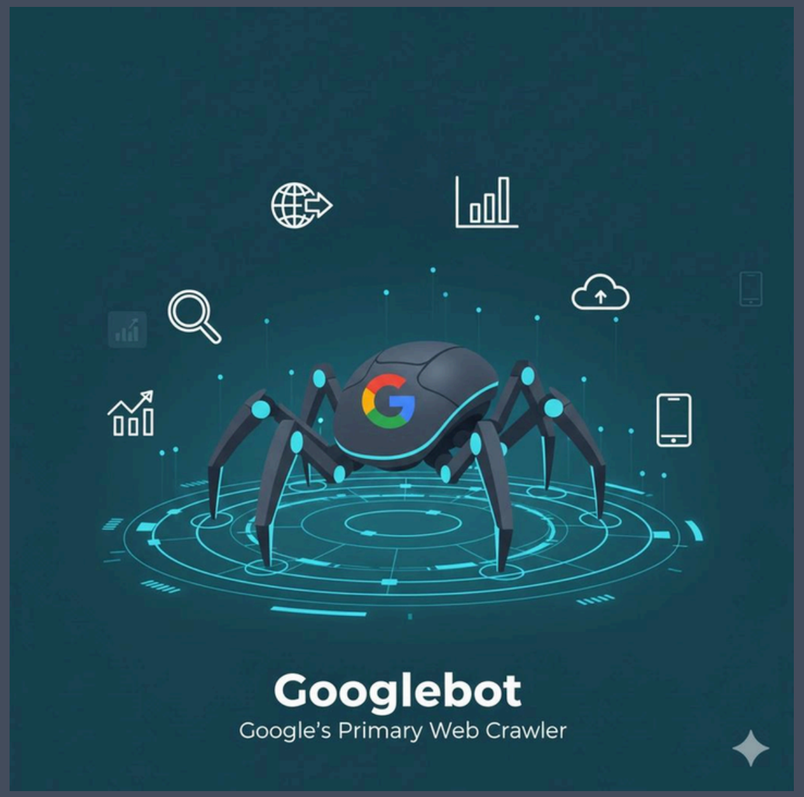
COMO VEMOS LA RED? | CRAWLERS

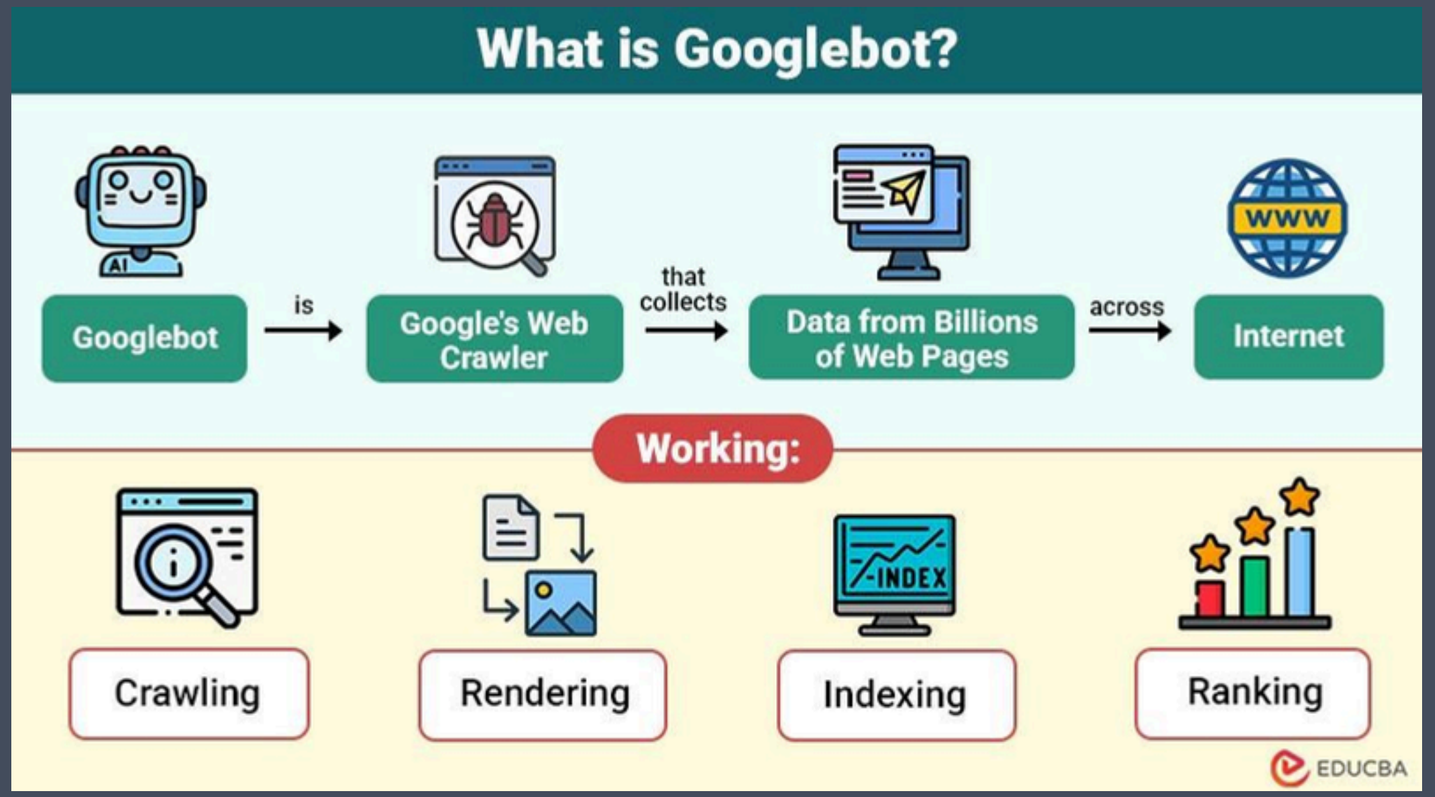
Proceso de 3 etapas:

1. CRAWLING (rastreo): Google envía programas automáticos llamados crawlers o rastreadores para descubrir páginas web y seguir sus enlaces.

2. INDEXING (indexación): Google analiza el contenido de las páginas y organiza la información que considera útil en su índice.

3. RANKING Y SEARCH (clasificación y búsqueda): Cuando haces una búsqueda, Google consulta su índice y ordena los resultados según su relevancia.


Googlebot
Google's Primary Web Crawler


What is Googlebot?
Googlebot
is
Google's Web Crawler
that collects
Data from Billions of Web Pages
across
Internet
Working:
Crawling
Rendering
Indexing
Ranking
EDUCBA

IndexPlease

How Indexing Process Works?



Crawling

Automated web crawlers or spiders systematically discover new web pages and updated pages across the web



Analyzing Content

Content, Structure, metadata and media are examined to understand a page's context



Indexing & Storing

Pages meeting certain criteria are added to the search index - a vast web page database



Ranking

Pages are ranked in search results by relevance, quality, user experience & backlinks

indexplease.com



El archivo robots.txt es un archivo de texto simple que los dueños de una página web crean para decirle a los crawlers (los robots de los buscadores) a qué partes de su sitio pueden entrar y a cuáles no. Es como un letrero de "No Pasar" o "Solo Personal Autorizado" en el mundo digital.


roject | Privacy Online
eveiligd | https://www.torproject.org
Home
About Tor
Anonymity Online
Protect your privacy. Defend yourself against network surveillance and traffic analysis.

HABLEMOS DE... TOR?

Tor no nació para cometer delitos ni para crear la Dark Web. ***Nació como una tecnología para proteger la privacidad y el anonimato de las comunicaciones en Internet.***

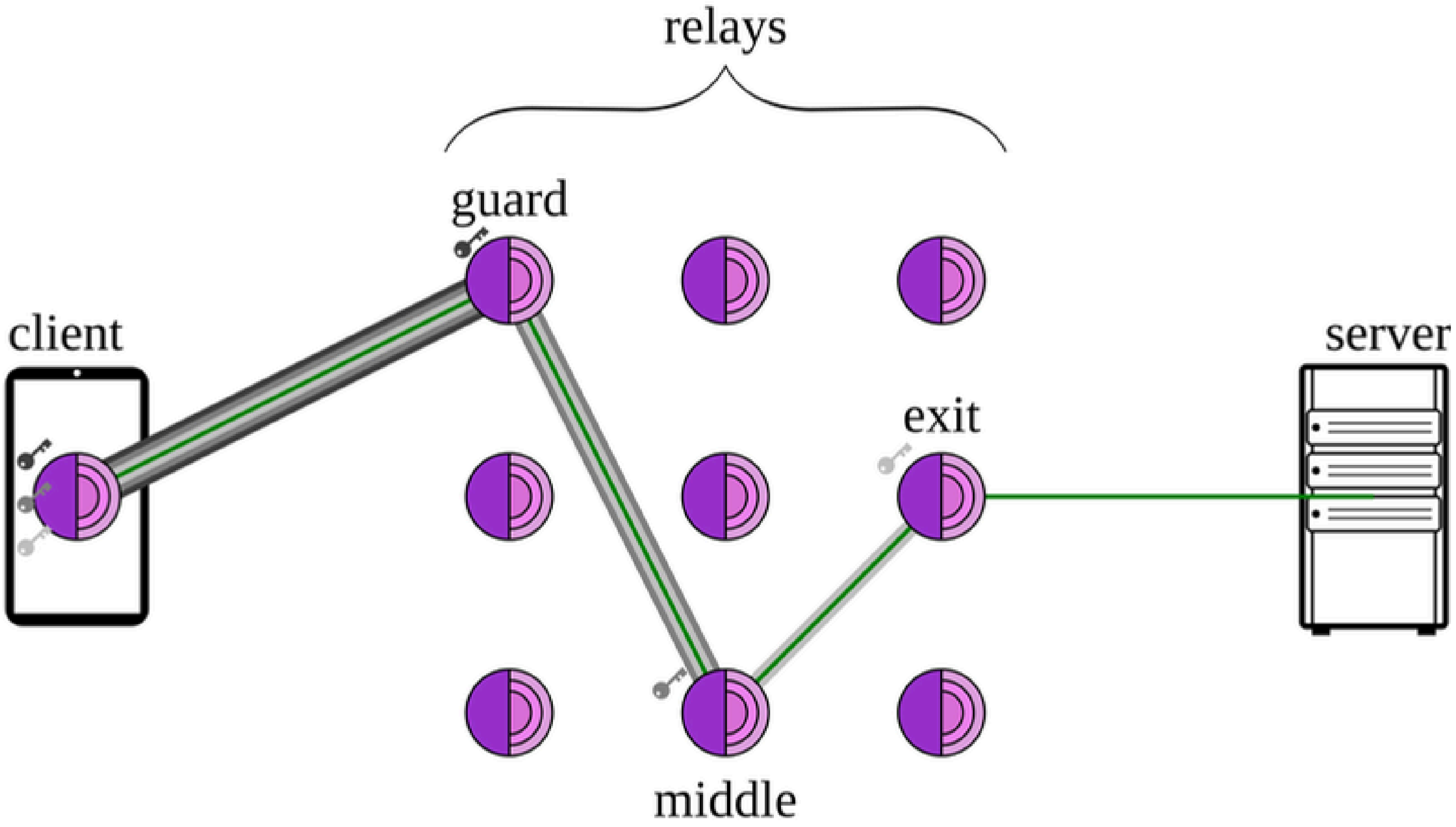
Tor significa The Onion Router (el enrutador cebolla).

Es una red que permite navegar por Internet intentando ocultar la dirección IP de origen mediante una serie de intermediarios llamados nodos o relays.

Una cebolla tiene varias capas.
Cuando la pelas, vas quitando una capa tras otra.

Tor utiliza una idea parecida: envuelve los datos en varias capas de cifrado para que cada intermediario conozca solamente la información necesaria para realizar su parte del recorrido.




relays
guard
client
server
exit
middle

MITO *VS* VERDAD

Tor es una red de anonimato. La dark web son los servicios ocultos (.onion) que corren sobre ella. Navegar a un sitio normal vía Tor no es “entrar a la dark web”.



03

TIPOS DE ATAQUE BASICOS, HACKERS Y OWASP



CIBERATAQUES

Un ciberataque es una accion realizada contra un sistema informatico, una red, aplicacion, o un usuario con el objetivo de comprometer su seguridad

- **Robar informacion:** contraseñas, datos bancarios, documentos.
- **Interrumpir servicios:** impedir que una pagina web funcione.
- **Obtener acceso:** entrar en sistemas sin autorizacion.
- **Modificar informacion:** alterar registros o archivos.
- **Extorsionar:** exigir dinero para recuperar informacion o servicios.

PHISHING

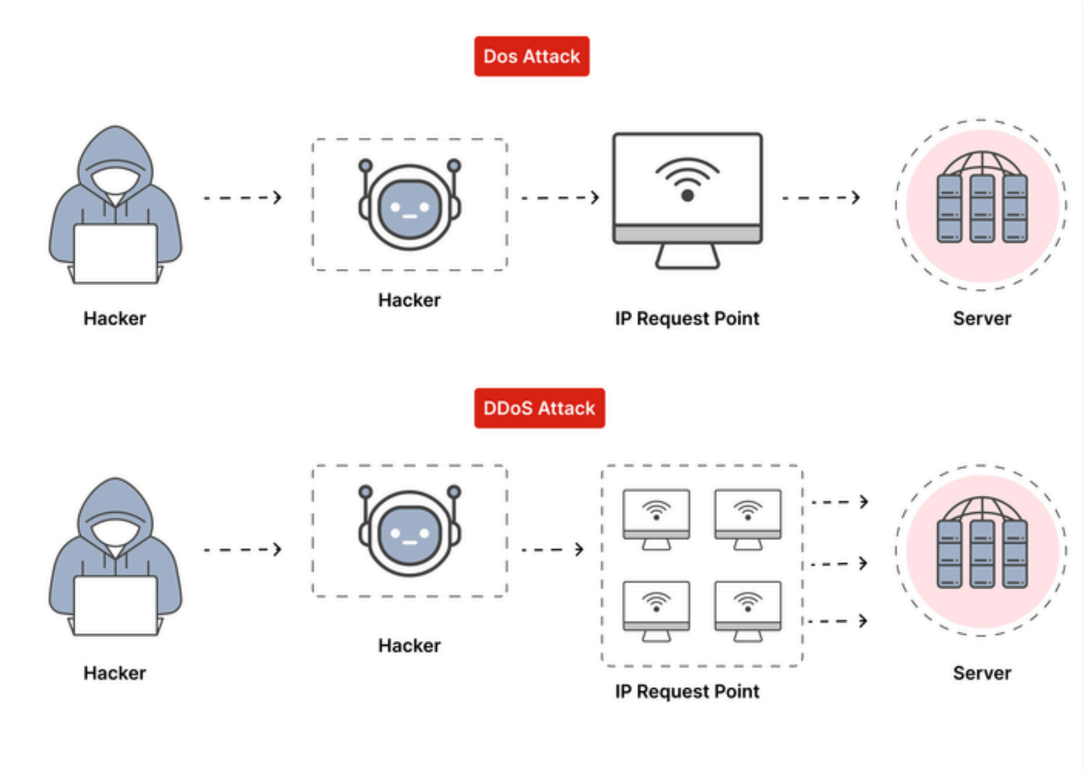
Phishing es un tipo de ataque en el que un delincuente se hace pasar por una persona, empresa u organizacion legitima para enganar a una victima y conseguir informacion o provocar una acción.

La palabra viene de fishing (pescar).

La idea es sencilla: el atacante lanza un anzuelo y espera que alguien caiga.



DOS Y DDOS



DoS significa Denial of Service, es decir, denegación de servicio.

Su objetivo es conseguir que un servicio deje de funcionar correctamente o que los usuarios legítimos no puedan acceder.

DDoS significa Distributed Denial of Service, o denegación de servicio distribuida.

Es parecido al DoS, pero existe una diferencia fundamental:

- **DoS:** el ataque procede de una fuente o un conjunto limitado de fuentes.
- **DDoS:** el tráfico malicioso procede de muchas fuentes distribuidas.

E-DOS

EDoS significa Economic Denial of Sustainability, que podemos traducir como denegación económica de sostenibilidad.

Busca provocar que mantener un servicio sea económicamente insostenible, especialmente en infraestructuras que utilizan servicios de computación en la nube (Cloud Computing).

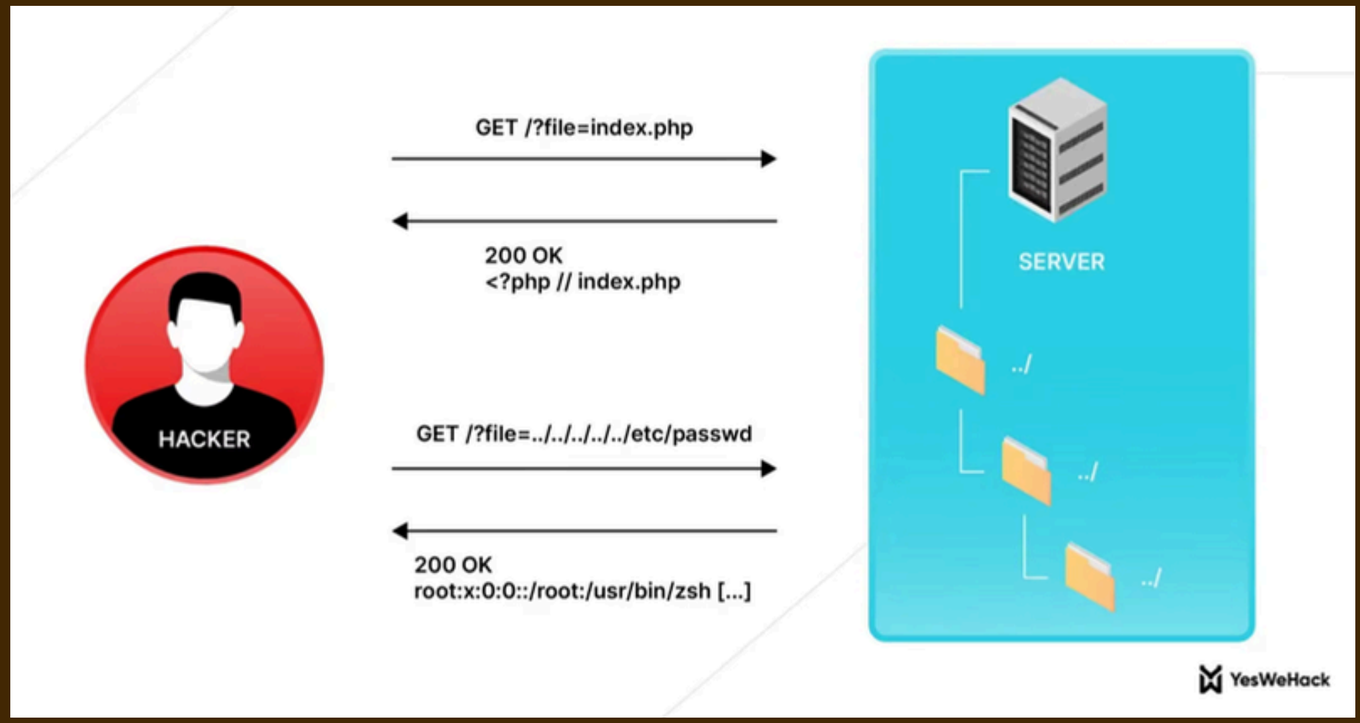
Un atacante provoca un consumo anormal de recursos mediante solicitudes que generan trabajo y costes.



PATH TRAVELSAL

El Path Traversal (también conocido como Directory Traversal o ataque del "punto punto barra" ../) es una vulnerabilidad de seguridad informática que permite a un atacante leer o escribir archivos no autorizados en el servidor que ejecuta una aplicación web

Ocurre cuando la aplicación web toma datos proporcionados por el usuario (como el nombre de un archivo, una imagen o un parámetro en la URL) y los utiliza para acceder al sistema de archivos del servidor sin una validación o filtrado estricto.



1. RANSOMWARE
(Cifrado de datos)



BLOQUEO Y EXIGENCIA DE RESCATE PARA RECUPERAR DATOS.

2. FUERZA BRUTA
(Adivinar contraseñas)



INTENTOS AUTOMATIZADOS PARA DESCUBRIR CLAVES Y ACCESOS.

3. MAN-IN-THE-MIDDLE / MITM
(Intercepción de datos)



CAPTURA Y MANIPULACIÓN DE COMUNICACIONES ENTRE USUARIOS.

4. ATAQUES DE DÍA CERO
(Vulnerabilidades sin parche)



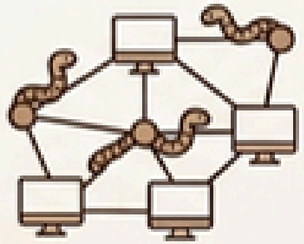
EXPLOTACIÓN DE FALLOS DESCONOCIDOS ANTES DE EXISTIR PROTECCIÓN.

5. SPYWARE
(Espionaje y robo de datos)



PROGRAMAS QUE MONITOREAN Y ROBAN INFORMACIÓN PERSONAL.

6. GUSANOS / WORMS
(Autorreplicación en red)



MALWARE QUE SE PROPAGA SOLO POR LA RED INFECTANDO DISPOSITIVOS.

7. INYECCIÓN DE PROMPTS / PROMPT INJECTION
(Manipulación de IA)

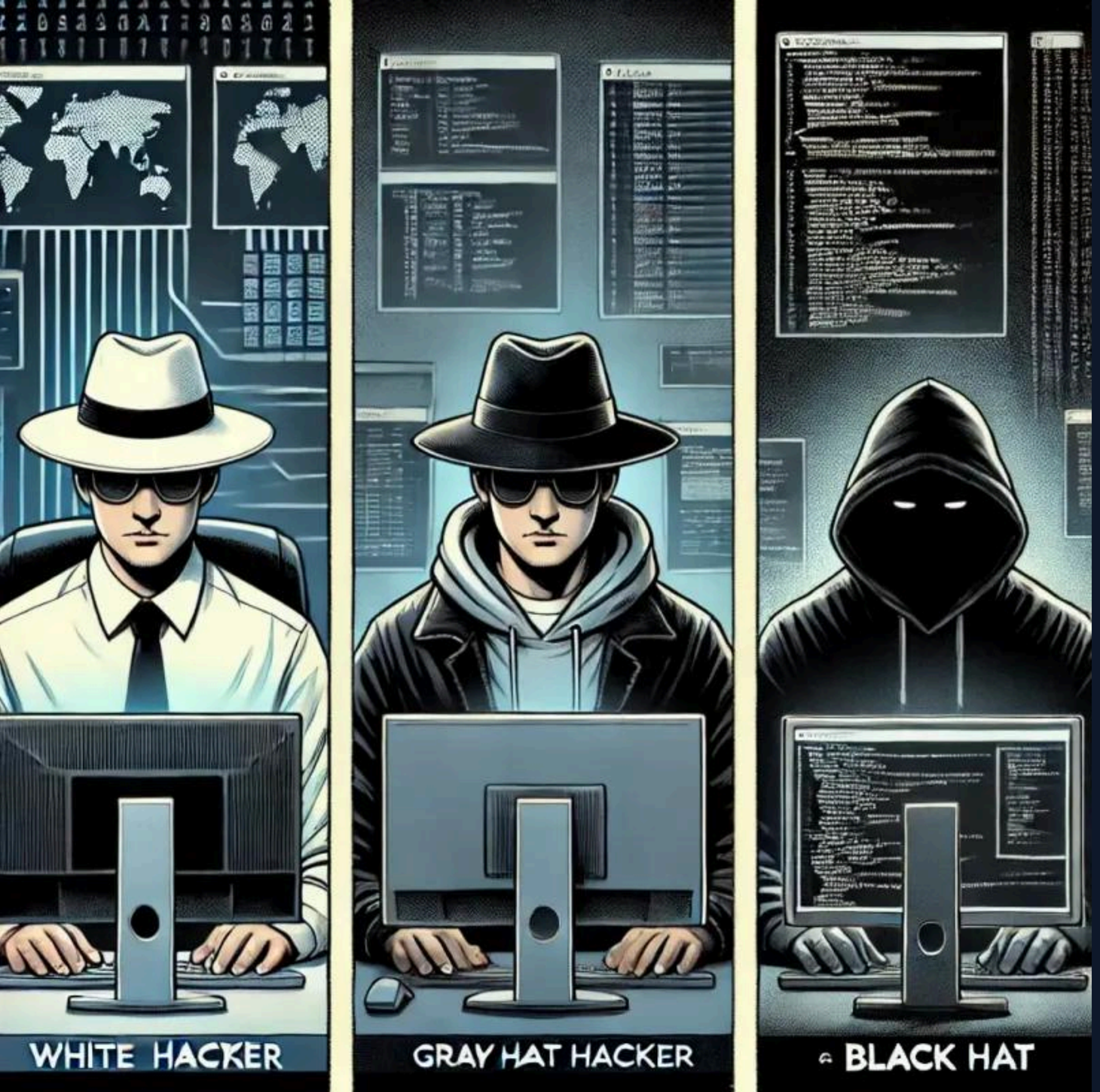


ENGAÑO A MODELOS DE IA PARA OBTENER SALIDAS MALICIOSAS.

8. DATA POISONING
(Contaminación de datos de IA)



CORRUPCIÓN DE DATOS DE ENTRENAMIENTO PARA ADULTERAR LA IA.



HACKERS POR COLOR?

WHITE HAT
(Hacker Ético)



GREY HAT
(Zona Intermedia)



BLACK HAT
(Hacker Malicioso)



	White Hat	Grey Hat	Black Hat
Intención	Constructiva	Variable	Destructiva
Autorización	Completa	Nula	Nula

HAY

“EQUIPOS”

TAMBIEN

LOS 3 EQUIPOS DE CIBERSEGURIDAD

RED TEAM
(Ofensiva)



Simula ataques reales para encontrar vulnerabilidades críticas.

Kali Linux, Metasploit, Nmap, Burp Suite, Cobalt Strike.

Pruebas de Penetración, Ingeniería Social.

BLUE TEAM
(Defensiva)



Protege sistemas, detecta amenazas y analiza logs.

Splunk, Wazuh, Microsoft Sentinel, Wireshark, Snort.

Monitorización 24/7, Respuesta a Incidentes, Gestión de Alertas.

PURPLE TEAM
(Colaboración)



Integra ambos lados para optimizar reglas de detección y lograr mejora continua.

Optimización de Detección, Colaboración y Sinergia, MITRE ATT&CK.

04

QUE TIENE QUE VER DESARROLLO Y OWASP TOP 10

¿Por qué importa a quien escribe código?

Gran parte de los ataques no explotan “el internet” en abstracto, sino errores en aplicaciones:

- Una consulta mal construida.
- Un permiso mal validado.
- Una contraseña olvidada en el repositorio.
- Una librería desactualizada.

Algunos de esos errores los introducen, sin querer, quienes desarrollan.



OWASP

Open Web Application Security Project

Top 10:2025 List

1. A01:2025 - Broken Access Control
2. A02:2025 - Security Misconfiguration
3. A03:2025 - Software Supply Chain Failures
4. A04:2025 - Cryptographic Failures
5. A05:2025 - Injection
6. A06:2025 - Insecure Design
7. A07:2025 - Authentication Failures
8. A08:2025 - Software or Data Integrity Failures
9. A09:2025 - Security Logging and Alerting Failures
10. A10:2025 - Mishandling of Exceptional Conditions

QUE ES?

El OWASP Top 10 es un documento de concienciación estándar para desarrolladores y seguridad de aplicaciones web.

Representa un amplio consenso sobre los riesgos de seguridad más críticos para las aplicaciones web.


OWASP
Open Web Application
Security Project
Why is it when something
happens, it is always you three?


Broken
Access
Control
SQL
XSS
Cross Site Scripting
Believe me, Professor, I've been asking
myself the same question for 6 years.

SPRINT FINAL: “FALTA SEGURIDAD”



DESPLIEGUE ES MAÑANA

CONTRASEÑA: ADMIN123



SUBIDA A GITHUB PÚBLICO

“ES TEMPORAL”



CÓDIGO EN PRODUCCIÓN DESDE 2019

05

GOBERNANZA, CUMPLIMIENTO, LEGAL

A QUIENES LES IMPORTA ESTO? (Stakeholders)

👥 Usuarios
Confían sus datos personales y dinero.

💼 Negocio
Quiere ingresos, reputación y cero multas.

👩‍💻 Desarrolladores
Construyen la confianza: código seguro por defecto.

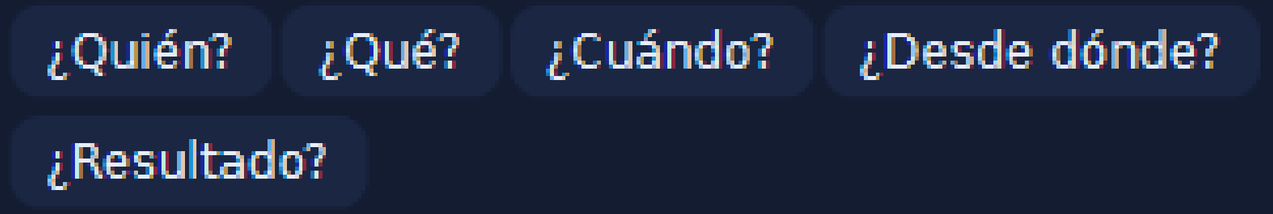
🛠️ Operaciones / TI
Despliegan, monitorean, responden a incidentes.

🏛️ Reguladores
Exigen cumplimiento: bancos, datos personales.

🤝 Proveedores
Librerías, nube, APIs: su riesgo es tu riesgo.

¿Por qué importa auditar? Trazabilidad

Auditar es verificar con evidencia que lo que decimos que hacemos es lo que realmente se hace. Sin registros no hay trazabilidad, y sin trazabilidad no hay investigación ni cumplimiento.



Dentro de la auditoria hay multiples herramientas que nos permiten dar control y orden a los procesos... o crearlos.

Matriz RASCI: ¿quién hace qué?

Tabla que deja claro el rol de cada persona en cada actividad, para evitar el clásico “yo pensé que lo hacía otro”.

Actividad	CEO / Gerencia	CISO	Líder Dev	Dev	DevOps	Legal
Definir la política de seguridad	A	R	C	I	C	C
Revisión de código (pull request)	I	C	A	R	S	-
Aplicar parches a servidores	-	A	I	-	R	-
Responder a un incidente	I	A	S	S	R	C
Notificar una brecha al regulador	A	S	I	-	-	R
Aprobar acceso a producción	-	C	A	I	R	-

R: Ejecuta · A: Aprueba y responde · S: Apoya · C: Asesora · I: Recibe información.

Matriz RBAC: permisos por rol

Recurso	Lector	Dev	DevOps	Admin
Repositorio de código	R	R/W	R	R/W/Adm
Base de datos de producción	—	—	R/W (restringido)	Adm
Gestor de secretos	—	—	Leer los suyos	Adm
Logs de auditoría	—	R	R	R/W
Consola de la nube	—	—	Despliegue	Adm

Role-Based Access Control: los permisos se asignan al rol, y las personas reciben roles.

Alguien cambia de puesto: cambias su rol, no 40 permisos sueltos. Auditar es leer una tabla.

Inventario de activos

Un activo es cualquier cosa que tenga valor para la organización: información, software, hardware, servicios, personas, instalaciones. Cada uno con un dueño.

ID	Activo	Tipo	Dueño	Ubicación
A01	Base de datos de clientes	Información	Gerente de negocio	Nube (región us-east)
A02	API de pagos	Software / servicio	Líder Dev	Kubernetes prod
A03	Repositorio de código	Información	Líder Dev	GitHub (SaaS)
A04	Sitio web institucional	Software	Marketing	Hosting externo
A05	Laptops del equipo dev	Hardware	TI	Oficina / remoto
A06	Equipo de soporte (conocimiento)	Personas	RR. HH.	—

Definir la criticidad

Se pregunta, por cada activo: ¿cuánto daño si se rompe C, I o A? Escala 1 (bajo) a 3 (alto). La criticidad es el valor más alto.

Activo	C	I	A	Criticidad	Por qué
A01 BD de clientes	3	3	2	ALTA	Datos personales: multa y pérdida de confianza
A02 API de pagos	3	3	3	ALTA	Sin ella no se cobra; alterar montos = fraude
A03 Repositorio	3	3	2	ALTA	Código y secretos; origen de la cadena de suministro
A04 Sitio web	1	2	2	MEDIA	Información pública; afecta imagen si cae
A05 Laptops dev	2	2	1	MEDIA	Reemplazables; el dato es el riesgo
A07 Impresora	1	1	1	BAJA	Sin datos sensibles

La criticidad decide dónde invertir primero. Los activos altos entran siempre al análisis de riesgo.

El mapa de calor: impacto × probabilidad

Una matriz que cruza probabilidad (qué tan posible es que ocurra) con impacto (qué tan grave sería). El color indica el nivel de riesgo.

Riesgo = Probabilidad × Impacto

Cada eje va de 1 a 5: el resultado va de 1 a 25.

Niveles

- 1-4 Bajo (aceptar/monitorear)
- 5-9 Medio (planificar)
- 10-16 Alto (tratar pronto)
- 17-25 Crítico (acción inmediata)

	Impacto 1	Impacto 2	Impacto 3	Impacto 4	Impacto 5
Prob. 5	5	10	**R2**	20	25
Prob. 4	4	8	12	16	**R1**
Prob. 3	3	**R6**	**R4**	12	**R3**
Prob. 2	**R7**	4	6	**R5**	10
Prob. 1	1	2	3	4	5

ID	Riesgo (activo)	PxI
R1	SQL injection en BD clientes (A01)	4x5=20
R2	Phishing a empleados con acceso (A03)	5x3=15
R3	Secretos filtrados en el repo (A03)	3x5=15
R4	DDoS contra el sitio / API (A02, A04)	3x3=9
R5	Falla de disco en servidor sin respaldo (A02)	2x4=8
R6	Pérdida de una laptop (A05)	3x2=6
R7	Falla de la impresora (A07)	2x1=2



Reporte FortiGuard Labs

Primer Trimestre 2021

Más de **7 mil millones** de intentos de ciberataques en América Latina y el Caribe

Crecen las amenazas de malware vía redes sociales

Malware basado en la web: Incremento en la **utilización de redes sociales** para difundir publicidad y sitios web engañosos. Los **usuarios comprometidos** comparten mensajes con contenido malicioso a sus **contactos desde sus perfiles de redes sociales**, sin tener conocimiento de ello.

1. Se recibe una campaña de phishing con método de propagación automática que utiliza los contactos de WhatsApp, Facebook o Instagram.
2. El usuario hace clic en un anuncio que ofrece premios o atractivos concursos, se lo redirige a la página de destino del kit de explotación.
3. Se descarga malware que crea "pop-ups" o anuncios con código malicioso oculto para propagarse y exfiltrar información.
4. El usuario comparte con sus contactos, generando el efecto de propagación.

El **phishing** es el principal **vector de acceso** para amenazas más sofisticadas como el **ransomware**.
Los ciberdelincuentes continúan aprovechando **las brechas en el trabajo remoto para acceder a las redes corporativas.**

FORTINET

INFORME FORTIGUARD LABS

PRIMER SEMESTRE **2022**



Intentos de **ciberataques**

México
85.000 millones
Un aumento del **40%** con respecto al mismo período de **2021**

América Latina
137.000 millones
Un aumento del **50%** respecto al mismo período de **2021**

Aumento de los ataques sofisticados y direccionados: **el ransomware**

Se detectaron aproximadamente **384.000** intentos de distribución de **ransomware** a nivel mundial. De ellos, **52.000** fueron dirigidos a **América Latina.**

México, Colombia y Costa Rica fueron los países más afectados, seguidos de **Perú, Argentina y Brasil.**

En tan solo seis meses, el número de firmas de **ransomware** encontradas en América Latina aumentó de **5.400 a 10.656.**

Las **Campañas de ransomware** más activas en la región fueron: **Revil, LockBit, Hive y Conti.**


FORTINET
INFORME DE FORTIGUARD LABS
Panorama Global de Amenazas
PRIMER SEMESTRE DE 2023
América Latina
63 mil millones
de intentos de ciberataques en el primer semestre de 2023
Argentina
1.200 millones
de intentos de ciberataques en el primer semestre de 2023


FORTINET
Informe de FortiGuard Labs
AÑO 2024
AMÉRICA LATINA
920 mil millones
de intentos de ciberataques en 2024
ARGENTINA
28 mil millones
de intentos de ciberataques en 2024

FORTINET

Informe de FortiGuard Labs

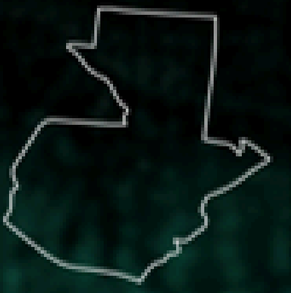
AÑO 2024



AMÉRICA LATINA

920 mil millones

de intentos de ciberataques en 2024



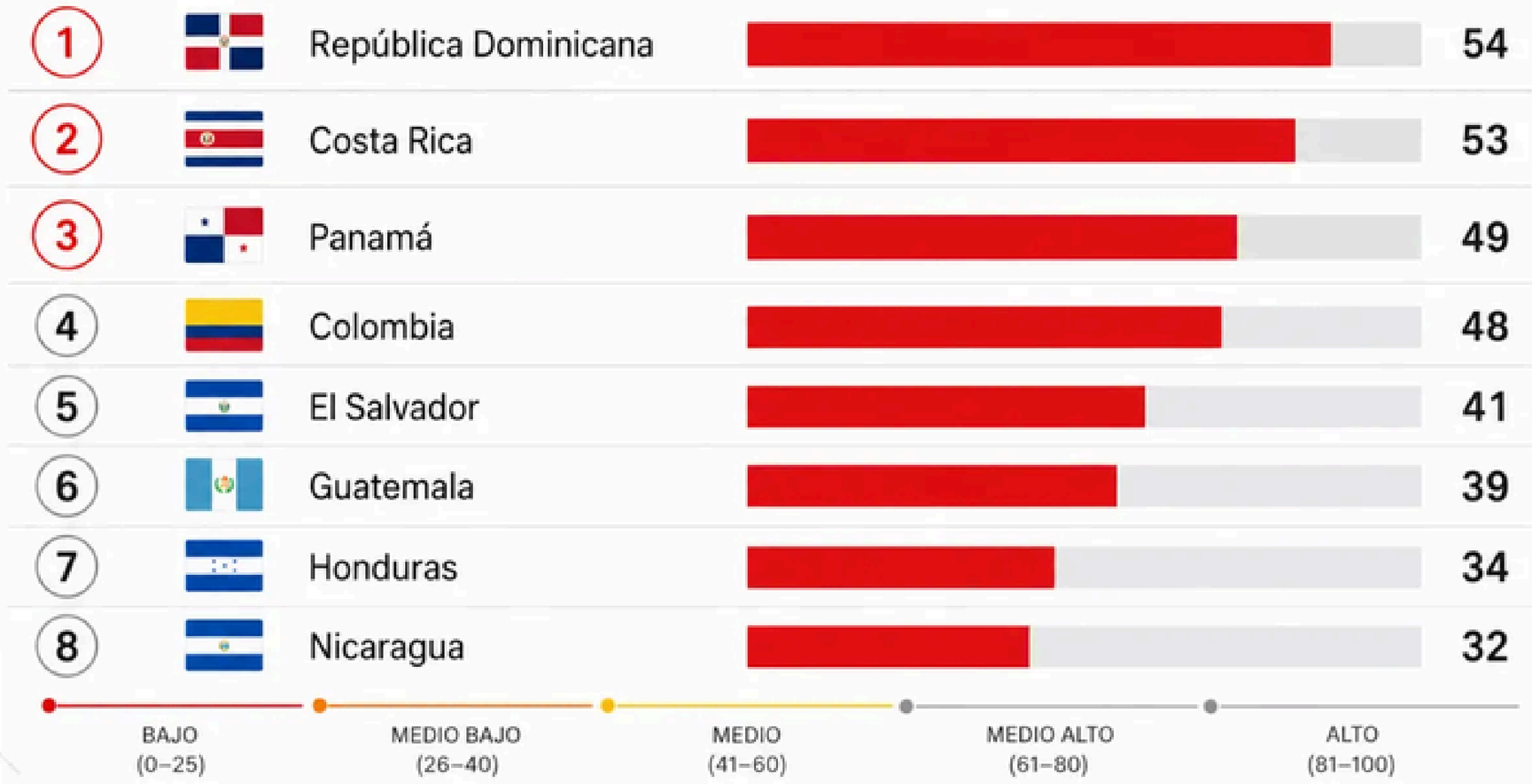
GUATEMALA

5.600 millones

de intentos de ciberataques en 2024

ÍNDICE REGIONAL DE RESILIENCIA CIBERNÉTICA

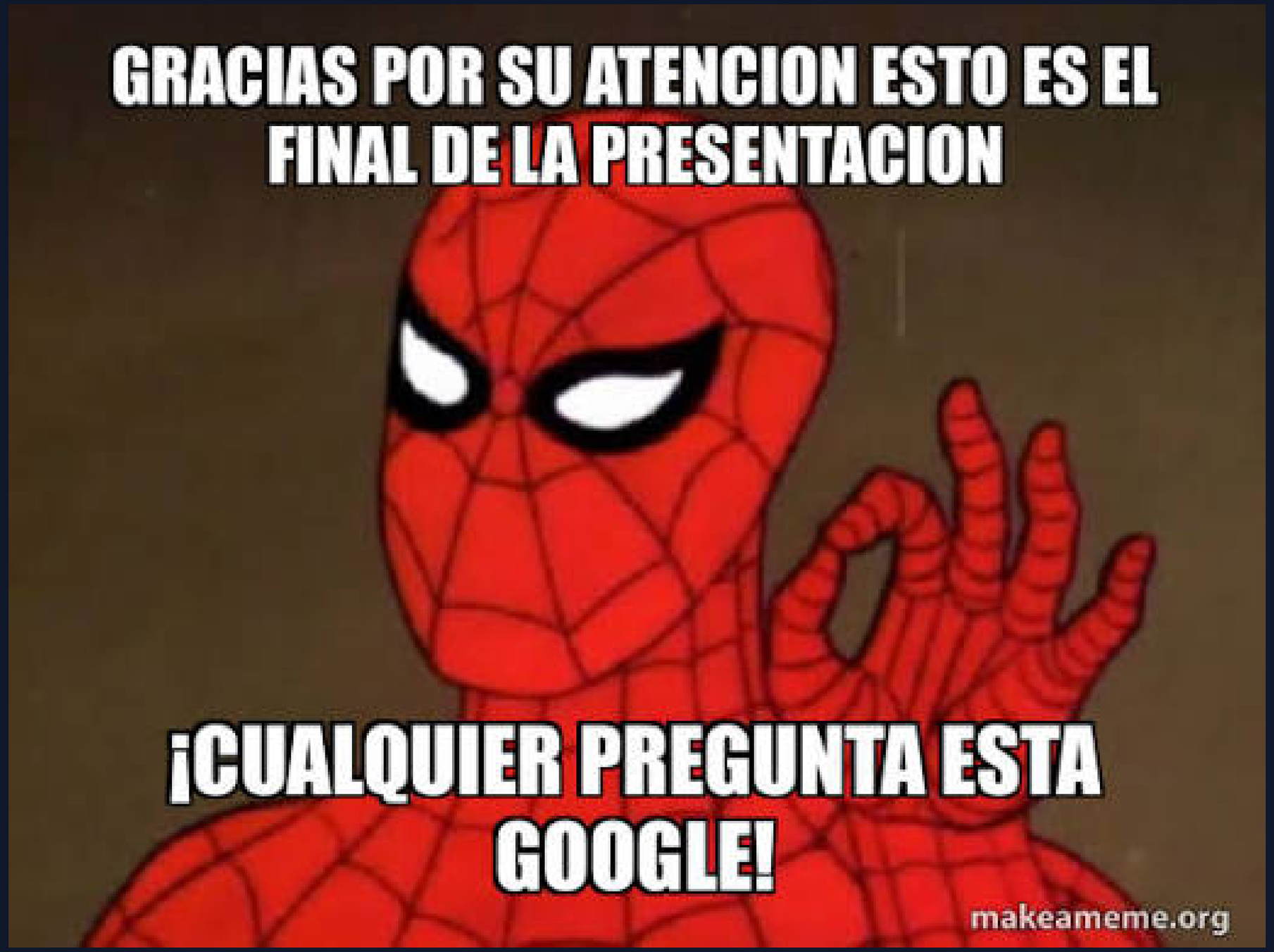
SISAP
Sistemas Aplicativos



Fuente: Sistemas Aplicativos (SISAP)



That's the end
of our presentation


GRACIAS POR SU ATENCION ESTO ES EL FINAL DE LA PRESENTACION
¡CUALQUIER PREGUNTA ESTA GOOGLE!
makeameme.org